

Deliberation SAN-2023-015 of October 12, 2023

National Commission for Information Technology and Freedoms

Nature of the deliberation: Sanction

Legal status: In effect

Date of publication on Légifrance: Thursday, October 19, 2023

Deliberation of the restricted formation No. SAN-2023-015 of October 12, 2023, concerning the company GROUPE CANAL +

The National Commission for Information Technology and Freedoms, convened in its restricted formation composed of Mr. Alexandre LINDEN, president, Mr. Philippe-Pierre CABOURDIN, vice-president, Ms. Christine MAUGÜÉ, and Messrs. Alain DRU and Bertrand du MARAIS, members;

Considering Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, on the protection of personal data and the free movement of such data;

Considering Directive 2002/58/EC of the European Parliament and of the Council of July 12, 2002, concerning the processing of personal data and the protection of privacy in the electronic communications sector;

Considering Law No. 78-17 of January 6, 1978, relating to information technology, files, and freedoms, notably its articles 20 and following;

Considering Decree No. 2019-536 of May 29, 2019, taken for the application of Law No. 78-17 of January 6, 1978, relating to information technology, files, and freedoms;

Considering Deliberation No. 2013-175 of July 4, 2013, adopting the internal regulations of the National Commission for Information Technology and Freedoms;

Considering the requests No. [...] ;

Considering Decision No. 2021-017C of January 21, 2021, of the president of the National Commission for Information Technology and Freedoms, assigning the Secretary General to carry out or have carried out a verification mission of the processing operations implemented by the company GROUPE CANAL + or on its behalf, in any location likely to be concerned by their implementation;

Considering the decision of the president of the National Commission for Information Technology and Freedoms designating a rapporteur before the restricted formation, dated March 9, 2023;

Considering the report of Ms. Valérie PEUGEOT, reporting commissioner, notified to the company GROUPE CANAL + on May 11, 2023;

Considering the written observations submitted by the company GROUPE CANAL + on June 12, 2023;

Considering the oral observations made during the session of the restricted formation on September 14, 2023;

Considering the other documents in the file;

Present at the session of the restricted formation:

- Ms. Valérie PEUGEOT, commissioner, heard in her report;

As representatives of the company GROUPE CANAL +:

- [...].

The company GROUPE CANAL + having spoken last;

The restricted formation adopted the following decision:

I. Facts and Procedure

1. Founded in 1998 in France, the company GROUPE CANAL + (hereinafter referred to as the "company") specializes in the publishing of channels and the distribution of pay television offers. In 2021, GROUPE CANAL + employed approximately 3,223 employees in France and achieved a turnover of 1,851,312,842 euros for the year 2022.

2. The company offers a service for publishing premium and thematic channels, in the production and distribution of cinema films and television series. It also publishes free channels on digital terrestrial television (DTT).

3. Between November 2019 and January 2021, the National Commission for Information Technology and Freedoms (hereinafter "the CNIL" or "the Commission") received 31 complaints, notably

concerning telemarketing, the transmission of banking data, and the exercise of rights. Five of these complaints were retained within the framework of the present procedure.

4. In accordance with Decision No. 2021-017C of January 21, 2021, of the president of the Commission, a delegation from the CNIL conducted several inspections at the company to verify compliance with the provisions of Law No. 78-17 of January 6, 1978, as amended, relating to information technology, files, and freedoms (hereinafter "the Data Protection Law" or "Law of January 6, 1978") and Regulation (EU)

2016/679 of the European Parliament and of the Council of April 27, 2016, concerning the protection of personal data and the free movement of such data (hereinafter the "Regulation" or "GDPR").

5. Thus, on January 26, 2021, the delegation conducted an online control mission regarding the processing operations carried out by the company or on its behalf, on the website www.canalplus.com. This control resulted in a report no. 2021-017/1, notified to the company on the same day.

6. On February 25, 2021, the delegation sent a questionnaire to the company, to which the latter responded on March 26, 2021, concerning its organization, the personal data processing it implements, its qualification as a data controller, its relationships with its clients and partners, and its management of requests to exercise rights.

7. From April 2021 to January 2022, the control delegation sent several additional requests to the company, which responded by providing the requested elements.

8. On March 9, 2023, the President of the Commission, based on Article 22 of the law of January 6, 1978, appointed Ms. Valérie PEUGEOT as the rapporteur for the purpose of examining these elements.

9. On March 30, 2023, the rapporteur sent an additional request to which the company responded on April 6, 2023.

10. On May 11, 2023, following her examination, the rapporteur notified the company of a report detailing the breaches of Articles 12, 13, 14, 15, 28, 32, and 33 of the GDPR and Article L. 34-5 of the Postal and Electronic Communications Code (hereinafter "the CPCE") that she deemed constituted in this case.

11. On June 12, 2023, the company submitted observations in response to the rapporteur's report.

12. By letter dated July 4, 2023, the rapporteur, in application of Article 40, III, of Decree No. 2019-536 of May 29, 2019, implementing the Data Protection Act, informed the company that the examination was closed.

13. By letter dated July 11, 2023, the company requested that a closed session be held for the meeting of the restricted formation. This request was rejected by the president of the restricted formation on July 24, 2023.

14. By an email dated August 14, 2023, the company communicated additional observations.

15. The rapporteur and the company presented oral observations during the meeting of the restricted formation on September 14, 2023.

16. [...], an expert in IT security from the company [...], a service provider of GROUPE CANAL +, was heard based on Article 22, paragraph 1, of the law of January 6, 1978.

II. Reasons for the Decision

A. On the grievances raised by the company in connection with the procedure

17. The company claims that it was led to produce defense elements that were not requested during the examination and which nonetheless pertain to determining factual information that could undermine the substance of certain grievances raised by the rapporteur.

18. It further considers that the exculpatory elements provided by GROUPE CANAL + were not taken into account, as the report was based on samples of information or a very partial perception of the

compliance measures taken by the company.

19. Firstly, the restricted formation notes that during the control mission, the company was able to respond to the requests of the CNIL services, provide any supporting documents, and share its observations. Each subsequent request for additional information made by the CNIL services was accompanied by a deadline allowing the company to gather the elements it deemed relevant to respond.

20. Secondly, the provisions of Article 40 of Decree No. 2019-536 of May 29, 2019, which notably provide that the natural or legal person to whom a report proposing a sanction is notified has a period of one month to submit its observations in response, have been respected. 21. In light of these elements, the restricted formation believes that the procedure is not tainted by irregularity.

B. On the failure to obtain the consent of the individuals concerned for the implementation of electronic commercial prospecting

22. According to Article L. 34-5 of the CPCE, "direct prospecting by means of automated electronic communication systems [...], by fax or by electronic mail using the contact details of a natural person [...] who has not previously expressed their consent to receive direct prospecting by this means is prohibited. For the application of this article, consent is understood as any manifestation of free, specific, and informed will by which a person agrees that personal data concerning them be used for direct prospecting purposes. [...]".

23. Article 4, paragraph 11, of the GDPR provides that "consent" of the data subject means "any manifestation of will, free, specific, informed, and unambiguous by which the data subject agrees, by a declaration or by a clear affirmative action, to the processing of personal data concerning them."

24. Article 7, paragraph 1, of the GDPR states that "in cases where processing is based on consent, the data controller shall be able to demonstrate that the data subject has given consent to the processing of personal data concerning them."

25. To propose to the restricted formation that the company has failed to meet its obligations arising from Articles L. 34-5 of the CPCE and 7, paragraph 1, of the GDPR, as clarified by the provisions of Article 4, paragraph 11, of the GDPR, the rapporteur relies on the fact that the company GROUPE CANAL +, which has electronic commercial prospecting operations carried out on its behalf by service providers, is not able to provide and demonstrate proof of validly expressed consent by the prospects to be approached in this way. Indeed, the data of these prospects comes from suppliers [...] (hereinafter " [...] "), in this case [...]. However, the rapporteur notes that these prospects, by checking the box provided on the collection forms to give their consent to receive commercial prospecting by electronic means, have not validly consented to receive prospecting from the company GROUPE CANAL +, as they were not informed of the identity of the prospector on behalf of whom the consent would be collected, the information not being available on the collection forms or via a clickable URL link.

26. In defense, the company argues that the responsibility for obtaining the lawful consent of the concerned prospects does not rest with it but with the [...] who are the source of the data collection and with whom it has entered into contracts distributing the responsibilities of each party. It adds that these [...] are responsible for sharing their clients' data. It also considers that the report does not specify the legal basis that would establish its own obligation to collect this consent. The company further asserts that the applicable regulation does not require informing individuals about the identity of the recipients of their data for consent to be considered validly obtained. It concludes that in light of these elements, the report disregards the principles of legality of offenses and penalties and the principle of personal responsibility.

27. Firstly, the restricted formation recalls that, pursuant to the combined provisions of Articles L. 34-5 of the CPCE and 7, paragraph 1, of the GDPR, as clarified by Article 4, paragraph 11, of the GDPR, the organization – in this case, the company GROUPE CANAL + – that carries out electronic commercial prospecting operations based on collected data by its partners, must have consent that constitutes a "manifestation of will, free, specific, informed, and unambiguous" from the individuals concerned. When the data of prospects has not been collected

directly from them by the organization conducting the prospecting, the consent may have been obtained at the time of the initial data collection by the primary collector, on behalf of the organization that will carry out subsequent prospecting operations. Failing that, it is the responsibility of the organization conducting the prospecting to obtain such consent before proceeding with prospecting activities. In accordance with the provisions of Article 7, paragraph 1, of the GDPR, the prospector must then be able to prove that it has obtained this consent. Furthermore, for the consent to be informed, individuals must be clearly informed of the identity of the prospector on behalf of whom the consent is collected and the purposes for which the data will be used. To this end, in cases where consent is collected by the primary collector on behalf of the prospectors, a comprehensive and updated list must be made available to individuals at the time of obtaining their consent, for example directly on the collection medium or, if it is too long, via a hyperlink directing to said list and the privacy policies of the service providers and suppliers (see in this regard, CNIL, FR, November 24, 2022, SANCTION, No. SAN-2022-021, published).

28. In this case, the restricted panel notes that 3,346,632 prospects whose data was collected from [...] and 588,324 from [...] were subject to electronic prospecting during the year 2021 by the service provider acting on behalf of the company GROUPE CANAL +. For all these prospects, the company is unable to provide documents demonstrating the valid acquisition of consent from the individuals, whether by its own means – which it specified it did not do – or by the primary collectors.

29. Indeed, while the company provided the control delegation with examples of standard data collection forms for prospects made available by [...], the restricted panel notes that no list of partners – including GROUPE CANAL + – that should be made available to prospects at the time of consenting has been communicated as part of the procedure. For the company [...], the collection form includes a checkbox with the following mention: "agree to receive commercial information for services/products [...] and partners." For the company [...], the mention specifies: "agree to receive commercial information from the companies of [...] or their partners according to my interests or my location." In both cases, no information about the identity of the concerned partners is available on the collection form or via a clickable hyperlink.

30. Thus, the company GROUPE CANAL + does not establish that it has valid consent from individuals for its electronic commercial prospecting operations. Indeed, even if individuals did give their consent to the companies [...] to receive electronic commercial prospecting by checking the boxes provided for this purpose on the relevant forms, they did not validly consent to receive prospecting from the company GROUPE CANAL +, as they were not informed of the identity of this prospector on behalf of whom the consent would be collected. The consent obtained cannot be considered as informed, as the individuals concerned were not informed of the identity of the prospector on behalf of whom the consent is collected, namely the company GROUPE CANAL +. In the absence of this information, the consent cannot be considered valid.

31. Secondly, the company asserts that the data of prospects would not be directly transmitted to it, but to service providers, and that the company would thus not be the recipient of the email addresses of the clients of [...], which are not in its database. The restricted panel considers that the circumstance whereby the company calls upon service providers to carry out prospecting operations does not affect the fact that, in order to rely on valid consent obtained by the primary collector, the company GROUPE CANAL + must be listed among the partners to whom the data is transmitted, since these subcontracting service providers act on its behalf. The company is responsible for the commercial prospecting it carries out, including when it is performed on its behalf by a subcontractor.

32. Thirdly, the restricted panel notes that, in the context of the document review, the company indicated that [...] is responsible for collecting the consent of the individuals concerned. The company specified that it exercises no control over the consent collection forms used, stating that "these forms are managed solely by the [...] concerned, in their capacity as data controller. Consequently, Groupe Canal+ is not responsible for defining the methods of collecting consent from the subscribers of [...]."

33. The restricted panel therefore considers that the measures implemented by the company GROUPE CANAL + to ensure with its partners that consent had been validly given by the prospects before approaching them were insufficient.

34. In these circumstances, the restricted panel considers that the company has failed to meet its obligations arising from Articles L. 34-5 of the CPCE and 7, paragraph 1, of the GDPR, as clarified by the provisions of Article 4, paragraph 11, of the GDPR.

C. On the breaches related to the obligation to inform the individuals concerned about the processing of their personal data

1) Regarding the information provided to users when creating an account for the MyCanal service

35. Article 12, paragraph 1, of the GDPR provides that "the data controller takes appropriate measures to provide any information referred to in Articles 13 and 14 as well as to carry out any communication under Articles 15 to 22 and Article 34 regarding the processing to the data subject in a concise, transparent, intelligible, and easily accessible manner (...)."

36. Article 13, paragraph 1, of the GDPR imposes on the data controller the obligation to provide the data subject with various information relating in particular to their identity and contact details, the purposes of the processing carried out, its legal basis, the recipients or categories of recipients of the data, and the fact that the data controller intends to carry out a transfer of data to a third country.

37. Article 13, paragraph 2, of the GDPR provides that, when necessary to ensure fair and transparent processing of data, the data controller must provide the individual with "the retention period for personal data or, when that is not possible, the criteria used to determine that period" and information regarding the "right to lodge a complaint with a supervisory authority."

38. The guidelines on transparency under Regulation (EU) 2016/679, which clarify the aforementioned provisions, specify that: "the retention period [...] should be formulated in such a way that the data subject can assess, depending on the situation in which they find themselves, what the retention period will be regarding specific data or in the case of specific purposes. The data controller cannot merely state in general terms that personal data will be retained as long as...

that the legitimate purpose of the processing requires it. Where applicable, different storage periods should be mentioned for the different categories of personal data and/or the different purposes of processing, including periods for archival purposes." 39. In this case, the rapporteur notes that when creating an account on the MyCanal service, a link located under the data collection form directs the user to a page titled "Personal Data and Privacy." She considers that the company's privacy policy does not sufficiently specify the data retention periods. She notes that it merely states that "your personal data is retained for periods determined in light of our purposes and the legal, tax, and accounting obligations incumbent upon us. The data related to your subscription is subject to electronic archiving for the entire duration of the subscription and for the legal limitation periods." Furthermore, the rapporteur observes that the possibility of filing a complaint with the CNIL is not mentioned in the privacy policy. 40. The company argues, on the one hand, that while the GDPR does require informing data subjects about the retention period of their data, neither the GDPR nor the G29 guidelines on transparency contain an indication regarding the degree of granularity expected for providing this information. The choice made by the company allows for transparency without excessively burdening its privacy policy. 41. However, it specifies that it modified its privacy policy on February 6, 2023, to provide more precise and granular information. 42. On the other hand, regarding the information about the possibility of filing a complaint with the CNIL, the company acknowledges that it was not included in the privacy policy at the time of the inspection but was added during its redesign. It clarifies that the information was, however, provided in the general terms of use, available on the website, and in the general subscription terms provided with each subscription to a service. 43. Firstly, regarding the data retention period, the restricted formation notes that the document, dated December 3, 2020, is not precise enough as it merely states that the data retention period is linked to the pursuit of certain purposes (compliance with legal, accounting, and tax obligations) or to the duration of the subscription, without indicating the specific applicable durations. The retention periods

are stated in a generic manner and are not sufficiently explicit, with the restricted formation also noting that some users of the service are not subscribers but have only created a personal space on the site. 44. However, the restricted formation considers that this information is important to ensure "fair and transparent processing" as it contributes to ensuring users have control over the processing of their data. 45. In light of the above, the restricted formation considers that the information regarding the retention period of users' data is not sufficiently detailed, which constitutes a breach of Article 13 of the GDPR. 46. The restricted formation does note, however, that the retention periods indicated in the privacy policy modified on February 6, 2023, are in compliance with the recommendations of the CNIL. 47. Secondly, the restricted formation notes that there is no mention of the right to file a complaint with the CNIL in the company's privacy policy, whereas this information is expressly referred to in Article 13, paragraph 2, d), of the GDPR. 48. However, it observes that the compilation of several documents, the right to access – were not communicated.⁶² The restricted formation emphasizes that the obligation to provide information under Article 14 of the GDPR is essential to ensure transparency and fairness in the processing of personal data.⁶³ It concludes that the failure to provide complete information during telemarketing calls constitutes a breach of the GDPR, specifically Article 14, as the individuals contacted did not receive the necessary information regarding the processing of their personal data.⁶⁴ The restricted formation also notes that the company must implement measures to ensure compliance with the GDPR and to prevent similar breaches in the future.⁶⁵ In light of these findings, the restricted formation recommends that the company take immediate corrective actions to address the identified deficiencies and to enhance its telemarketing practices in accordance with the GDPR.

different rights – were not brought to their attention, and the company did not implement a method allowing the concerned individuals to obtain more complete information regarding the processing of their data, for example, through the activation of a key on the telephone keypad. However, the restricted panel notes that all the calls referred to by the rapporteur lasted at least thirty seconds, and that the tele-advisor would therefore have had time to proceed, for example, to refer to the privacy policy of GROUPE CANAL +. Finally, the restricted panel considers that while the recordings provided to the CNIL do not reveal the existence of a structural failure in terms of information, it nonetheless failed to meet its obligations in the context of the aforementioned calls. Under these conditions, the restricted panel considers that the breach of Article 14 of the GDPR is established.

D. On the breach of obligations related to the modalities for exercising the rights of individuals

According to Article 12, paragraph 3, of the GDPR, "the data controller provides the data subject with information on the measures taken following a request made under Articles 15 to 22, without undue delay and in any event within one month of receiving the request. If necessary, this period may be extended by two months, taking into account the complexity and number of requests. The data controller informs the data subject of this extension and the reasons for the delay within one month of receiving the request. When the data subject submits their request electronically, the information is provided electronically where possible, unless the data subject requests otherwise."

According to Article 12, paragraph 4, of the GDPR, "If the data controller does not take action on the request made by the data subject, it shall inform the data subject without delay and at the latest within one month of receiving the request of the reasons for its inaction and of the possibility of lodging a complaint with a supervisory authority and seeking a judicial remedy."

The rapporteur, in proposing to the restricted panel to consider that the company has failed to meet its obligations arising from Article 12 of the GDPR, relies on the submissions of three complainants, Mr. [...] (submission no. [...]) and Ms. [...] (submission no. [...]) and [...] (submission no. [...]). The first two report difficulties encountered in the erasure of their personal data, while the third concerns a request for opposition.

The rapporteur observes that it appears from the findings made during the control procedure that these requests were processed by the company but without the concerned individuals being informed of the outcomes of their requests. Furthermore, regarding the opposition request, it was processed by the company outside the deadlines provided for by the GDPR.

In defense, concerning the two erasure requests, the company indicates that each of them concerned a request for termination and a request for erasure. Due to a misclassification of the request, the erasure was indeed processed but the concerned individual was not notified. The company argues that these are isolated cases and that the erasure request was properly handled.

Regarding the opposition request, the company considers that the complainant's initial request was not identified as such by the customer service. However, in the context of the document review, the company became aware of the existence of the complaint and contacted the complainant. The request was ultimately identified as a request for opposition to commercial solicitations, which was processed on the same day.

The restricted panel first notes that the requests made by the the obligations arising from Article 15 of the GDPR is established.

E. On the breach regarding the right of access of the data subjects

74. Article 15, paragraph 1, of the GDPR provides the right for a person to obtain from the data controller confirmation as to whether or not personal data concerning them is being processed and, when it is, access to such personal data as well as certain information, notably "when the personal data has not been collected from the data subject, any available information as to their source." It is also provided in paragraph 3 of the same article that "the data controller shall provide a copy of the personal data undergoing processing."

75. The rapporteur, in proposing to the formation to consider that the company has failed to meet its obligations arising from Article 15 of the GDPR, relies on three complaints to the CNIL, originating from Mr. [...] (n° [...]) and [...] (n° [...]) and Ms. [...] (n° [...]), these individuals reporting the absence of a response from the company to their requests.

76. The company acknowledges an error or malfunction in the qualification of the subject of the request concerning complaint n° [...] and claims to have never received the request related to complaint n° [...].

77. On the other hand, regarding complaint n° [...], the company considers that the complainant's request was not precisely formulated as a request for access to her personal data. It believes that it was a request for proof of a subscription contract, which does not fall under the GDPR.

78. The restricted formation first notes that it appears from the elements of the file that the requests from the complainants were indeed all received by the company.

79. Next, it considers that the requests were formulated in sufficiently clear terms. Regarding complaint n° [...], the complainant asked the company to "send her the elements you have as soon as possible, or failing that, to cancel this ongoing contract and also to proceed with the deletion of personal data [...] in accordance with the provisions of Article 17.1 of the General Data Protection Regulation." The complainant thus explicitly expressed the wish to obtain the transmission of the elements held by the company. This should have led the company to treat the request as a request for access and then for deletion.

80. Finally, the restricted formation considers that while the complaints received by the CNIL do not reveal the existence of a structural breach regarding the exercise of the right of access, it nonetheless remains that the company has failed to meet its obligations in processing the requests addressed to it.

81. In these conditions, the restricted formation considers that the breach of the obligations arising from Article 15 of the GDPR is established.

Article 15 of the GDPR is constituted. F. On the failure to comply with the obligation to frame the processing carried out on behalf of a data controller by a formal legal act. 82. Article 28, paragraph 3, of the Regulation provides that processing carried out by a processor on behalf of a data controller is governed by a contract or any other formal legal act that defines the subject matter and duration of the processing, the nature and purpose of the processing, the type of personal data, the categories of data subjects, as well as the obligations and rights of the data controller. This contract also stipulates the

conditions under which the processor undertakes to carry out processing operations on behalf of the data controller. 83. The rapporteur noted that several subcontracting contracts related to the hosting of personal data, provided by the company, did not contain all the mentions required by the aforementioned article. She points out that contracts with [...] were concluded before the GDPR came into force and have not since been updated to include the mentions required by Article 28, paragraph 3, of the Regulation. 84. In defense, the company claims that it terminated the hosting services provided by [...] as of 2016, that is, before the GDPR came into force. This service having been transferred to another processor, the contract was not updated. Regarding the contract with [...], the company asserts that amendments were signed until 2022 and that these amendments are supplemented by contracts related to the processing of personal data containing all the mentions prescribed by the GDPR. The contractual relationship with [...] ended on June 27, 2023. Regarding the contract with [...], the company indicates that the contract contains several documents, one of which was not communicated to the CNIL during the document inspection. The combination of these documents would show that the mentions required by the GDPR indeed frame the contractual relationship between the two parties. Following the acquisition of [...] by the company [...], a new contractual framework including an annex "Data Processing" is also under discussion. 85. The restricted formation notes that many elements were communicated by the company as part of the sanction procedure, after the notification of the report. 86. In light of these elements, it appears that regarding the contract governing the relations with [...], these ended in 2016, before the GDPR came into effect, so that the failure is not constituted. 87. Regarding the acts framing the relations with the company [...], in light of the original contract concluded with [...] which was communicated in response to the sanction report, and which complements that communicated by GROUPE CANAL + during the inspections, the restricted formation notes that all the mentions required by Article 28 of the GDPR are indeed present in the contracts when the two documents are read together. The failure is therefore not constituted for the framing of these relations. 88. Finally, regarding the contract concluded with [...], the amendments to the contract were not communicated to the CNIL services as part of the inspection procedure, which the company acknowledges. During the document inspection on February 25, 2021, the company provided the CNIL delegation with a contract dated 2019, concluded for a duration of one year, which did not include all the mentions required under Article 28, paragraph 3, of the GDPR. Subsequently, in response to the sanction report, it provided amendments that would have been concluded upon the expiration of this contract, and which would have been renewed since. The restricted formation notes that these new documents now contain all the necessary mentions. However, it observes that these documents provided are unsigned and appear to be working versions (some contain a yellow-highlighted mention indicating " [...] Cloud Service Agreement for INSERT DESCRIPTION OF THE SYSTEM " and " contract number " without the contract number). Furthermore, the only date indicated is a "revised" version from March 4, 2022. These observations regarding the form of the documents provided in defense having been raised, the restricted panel considers, in any event, that it is not necessary to determine whether the amendments provided constitute admissible evidence insofar as the breach is indeed established for past facts, in light of the findings made by the delegation at the time of the inspection. 89. In these circumstances, the restricted panel considers that the breach of Article 28, paragraph 3, of the GDPR is established for past facts concerning the contract governing the relations with [...]. G. On the breach of the security obligation 90. Article 32, paragraph 1, of the GDPR provides that "Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing as well as the risks, the likelihood and severity of which vary, for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk [...]" and in particular "means to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services" and a "procedure for regularly testing, assessing, and evaluating the effectiveness of the technical and organizational measures to ensure the security of processing." 91. The rapporteur considers that the storage of employees' passwords by the company in the application [...] in a hashed form using the MD4 algorithm is not compliant with the state of the art. 92. In defense, the company points out that the insufficiency of security measures mentioned in the sanction report is

not established. It claims that the report is based on short responses provided to targeted questions posed during the inspection, which were not intended to allow the CNIL to be fully informed of the overall level of security surrounding the passwords processed by the company. It argues that other measures would be implemented by the company to ensure an appropriate level of security, such as continuous monitoring of activity within the IT network or a limited number of administrator accounts. It also specifies that a policy of migration to a new version of Windows Server prompted it to upgrade the algorithms used to more robust versions, with migration completed in February 2023. Since then, the algorithm chain [...] has been used. 93. The company further considers that the rapporteur wrongly relies on deliberation No. 2022-100 of July 21, 2022, adopting a recommendation regarding passwords and other shared secrets and repealing deliberation No. 2017-012 of January 19, 2017, which has no normative character, is subsequent to the inspection, and allows for the implementation of supplementary measures to passwords alone. Its violation could therefore not be subject to sanction. 94. The restricted panel recalls that it follows from the provisions of Article 32 of the GDPR that the data controller is required to ensure that the automated processing of data it implements is sufficiently secure. The sufficiency of security measures is assessed, on the one hand, in light of the characteristics of the processing and the risks it entails, and on the other hand, taking into account the state of knowledge and the cost of measures. 95. The establishment of a robust authentication policy constitutes a fundamental security measure that generally contributes to compliance with the obligations of Article 32 of the GDPR. Thus, in terms of authentication, it is necessary to ensure that a password allowing authentication on a system cannot be disclosed. The secure storage of passwords constitutes a basic precaution in terms of personal data protection. As early as 2013, the National Cybersecurity Agency of France (ANSSI) alerted and reminded best practices regarding password storage, indicating that they "must be stored in a transformed form by a one-way cryptographic function (hash function) that is slow to compute, such as PBKDF2" and that "the transformation of passwords must involve a random salt to prevent a precomputed table attack" (ANSSI, "CERTA-2013-ACT-046 News Bulletin," November 15, 2013, <https://www.cert.ssi.gouv.fr/actualite/CERTA-2013-ACT-046/>). Similarly, in its deliberation No. 2017-012 of January 19, 2017, adopting a recommendation regarding passwords, the CNIL already indicated that it "recommends [that the password] be transformed using a non-reversible and secure cryptographic function (i.e., using a publicly recognized strong algorithm whose software implementation is free of known vulnerabilities), incorporating the use of a salt or a key." Indeed, non-robust hash functions present known vulnerabilities that do not guarantee the integrity and confidentiality of passwords in the event of a brute force attack after the compromise of the servers hosting them.

96. However, the restricted formation notes that the MD4 algorithm, used by the company for the storage of employee passwords at the time of the audits, was already considered obsolete and insufficiently robust to ensure the confidentiality of passwords at the date of the findings made by the delegation. Indeed, the MD4 hash function has been known to have a vulnerability for several years and is immediately exploitable by attackers (presenting a collision risk) (See in this regard ANSSI, "CERTFR-2014-ACT-028 News Bulletin," July 11, 2014, <https://www.cert.ssi.gouv.fr/actualite/CERTFR-2014-ACT-028/>). While the company argued that the positions taken by ANSSI in documents from 2014 have since been replaced by more recent documents, it remains that a hash function that was no longer state-of-the-art in 2014 was not any more so at the time of the audits. The use of the MD4 algorithm indeed requires resorting to the NTLM protocol for authentication, whereas this protocol was already criticized by ANSSI at the time of the audits (See in this regard ANSSI, "Recommendations for the Protection of Essential Information Systems," December 18, 2020, https://www.ssi.gouv.fr/uploads/2020/12/guide_protection_des_systemes_essentiels.pdf). The use of this hash function therefore does not guarantee the security of the personal data concerned. The restricted formation also considers that the robustness of peripheral security measures is not sufficient to compensate for the use of the MD4 algorithm. Indeed, the inherent fragility of the hash function used, on which the security of the storage of the company's employees' passwords is based, is such

that it cannot be rectified by other measures.

97. Under these conditions, the restricted formation considers that the breach of Article 32 of the GDPR is constituted.

98. The restricted formation notes that, since February 2023, the company has been using a new version of Windows Server that employs an algorithm compliant with the state of the art.

H. On the breach of the obligation to notify the CNIL of a personal data breach

99. Article 4.12 of the GDPR defines

of personal data is not a violation of the GDPR if it does not pose a risk to the rights and freedoms of individuals. The company argues that the data in question was not sensitive and that the number of affected individuals was minimal, thus justifying its decision not to notify the CNIL.

106. The report further states that the company failed to demonstrate that it had implemented appropriate technical and organizational measures to ensure the security of personal data. The absence of such measures raises concerns regarding the company's compliance with the GDPR.

107. The rapporteur emphasizes the importance of timely notification in the event of a data breach, as stipulated in Article 33 of the GDPR. The failure to notify the CNIL not only contravenes legal obligations but also undermines the trust of subscribers in the company's ability to protect their personal data.

108. In conclusion, the rapporteur recommends that the company be held accountable for its failure to notify the CNIL of the data breach, as this constitutes a violation of Article 33 of the GDPR. The company is urged to review and enhance its data protection practices to prevent future occurrences and ensure compliance with applicable regulations.

temporary confidentiality, which allowed seven people to view the data of other clients, lasted only 5 hours and 35 minutes. It adds that the data in question is not sensitive and that the individuals who were able to view it are other subscribers, without malicious intent and without specific expertise enabling them to extract the accessible data. It also specifies that the exact number of individuals who could have accessed the data of 10,154 subscribers is unknown. However, it would be limited to a maximum of 777 individuals, who were, according to the company, technically capable of accessing it. 106. The restricted formation first notes that the number of individuals affected by the breach, 10,154, is not negligible. It notes that several individuals have indicated to the company that they indeed had access to third-party data. The restricted formation then notes that the personal data made accessible by the breach was of a nature that could infringe upon the right to respect for the privacy of the subscribers since their postal address and phone number had been disclosed. Consequently, the company should have proceeded with the notification of the personal data breach to the CNIL. 107.

Under these conditions, the restricted formation considers that the breach of Article 33 of the GDPR is constituted. III. On the imposition of corrective measures and publicity 108. Article 20 of Law No. 78-17 of January 6, 1978, as amended, provides that: "when the data controller or its processor fails to comply with the obligations arising from Regulation (EU) 2016/679 of April 27, 2016, or from this law, the president of the National Commission for Computing and Liberties may [...] refer the restricted formation of the commission with a view to the imposition, after adversarial proceedings, of one or more of the following measures: [...] 7° Except in cases where the processing is carried out by the State, an administrative fine not exceeding 10 million euros or, in the case of a company, 2% of the total global annual turnover of the previous financial year, the higher amount being retained. In the scenarios mentioned in paragraphs 5 and 6 of Article 83 of Regulation (EU) 2016/679 of April 27, 2016, these ceilings are raised, respectively, to 20 million euros and 4% of said turnover. The restricted formation takes into account, in determining the amount of the fine, the criteria specified in the same Article 83." 109. Article 83 of the GDPR, as referred to by Article 20, paragraph III, of the Data Protection and Liberties Law, provides that: "Each supervisory authority ensures that the administrative fines imposed under this article for violations of this regulation referred to in paragraphs 4, 5, and 6 are, in each case, effective, proportionate, and dissuasive," before specifying the elements to be taken into account to decide whether to impose an administrative fine and to determine the

amount of that fine.¹¹⁰ Firstly, regarding the principle of imposing a sanction, the company indicates that, in addition to contesting the breaches alleged by the rapporteur or justifying them, it has already taken measures to remedy some of the alleged facts and ensure its compliance with the applicable legislation. It adds that some of the grievances made against it by the rapporteur are based on recommendations and a framework from the CNIL that do not have binding value and which are moreover subsequent to the facts in question. It further emphasizes that several of the alleged breaches are not substantial in this case and that they have represented a limited or even non-existent impact on the rights and freedoms of the individuals concerned. Finally, it insists on the goodwill and efforts it has demonstrated throughout the procedure. The company considers that the mitigating factors provided for by Article 83,

****Paragraph 2**** of the GDPR should lead the restricted formation not to impose a financial sanction, or at the very least, to significantly reduce the amount of the fine proposed by the rapporteur.

****111.**** The restricted formation recalls that it must take into account, for the imposition of an administrative fine, the criteria specified in Article 83 of the GDPR, such as the nature, gravity, and duration of the violation, the measures taken by the data controller to mitigate the damage suffered by the data subjects, the degree of cooperation with the supervisory authority, and the categories of personal data concerned by the violation.

****112.**** The restricted formation emphasizes that the breaches committed by the company involve, for some, obligations related to the fundamental principles of personal data protection and that numerous breaches are constituted. It notes that some of these breaches are structural and of a certain severity, while others present a lesser severity.

****113.**** Thus, concerning the collection of consent for electronic marketing purposes, the restricted formation recalls that the company processes a significant number of data for commercial prospecting purposes. Indeed, it emerges from the elements communicated by the company that 3,934,956 prospects were approached electronically in 2021.

****114.**** The restricted formation takes into consideration, as mitigating factors, the measures taken by the company, which has complied with certain points, as well as the low severity of some breaches, notably the fact that the cold calls for which the breach related to information is retained concern only a small part of the approached individuals. The restricted formation further notes, in light of the submissions presented during the debates, that the breaches of the rights of individuals are not structural and mainly result from human errors. It finally points out the isolated nature of the contract for which the supporting documents do not allow for a conclusion of compliance with the requirements of the GDPR.

****115.**** In view of all these elements, the restricted formation considers that it is appropriate to impose an administrative fine for the breaches of Articles 7, paragraph 1, 12, 13, 14, 15, 28, 32, and 33 of the GDPR and Article L. 34-5 of the CPCE.

****116.**** Secondly, the restricted formation recalls that the violations of the GDPR identified in this case involve breaches of principles that may be subject, under Article 83 of the GDPR, to an administrative fine of up to 20,000,000 euros or up to 4% of the total annual worldwide turnover of the previous financial year, with the higher amount being retained.

****117.**** It also recalls that administrative fines must be both dissuasive and proportionate. It particularly considers that the activity of the company and its financial situation must be taken into account for determining the amount of the administrative fine. In this regard, it notes that the company GROUPE CANAL + achieved a turnover of 1,851,312,842 euros in 2022.

****118.**** Therefore, in light of the company's responsibility, its financial capabilities, and the relevant criteria of Article 83, paragraph 2, of the GDPR mentioned above, the restricted formation believes that a fine of 600,000 euros is justified.

****119.**** Thirdly, regarding the publicity of the sanction, the company requests the restricted formation not to make its decision public.

****120.**** The restricted formation, on the contrary, considers that the publicity of this decision is justified in light of the severity of some of the breaches in question, the scope of the processing, and the number of individuals concerned.

****121.**** It also notes that this measure will allow informing the individuals affected by the company's prospecting operations. This information will enable them, if necessary, to assert their rights against the company.

****122.**** Finally, it believes that this measure is proportionate since the decision will no longer specifically identify the company after a period of two years from its publication.

****FOR THESE REASONS**** The restricted formation of the CNIL, after deliberation, decides to:

- impose an administrative fine against the company GROUPE CANAL + in the amount of six hundred thousand euros (600,000 €) for breaches of Articles 7, paragraph 1, 12, 13, 14, 15, 28, 32, and 33 of the GDPR and Article L. 34-5 of the Code of Postal and Electronic Communications;
- make public, on the CNIL website and on the Légifrance website, its deliberation, which will no longer allow for the specific identification of the company after a period of two years from its publication.

****The President**** Alexandre LINDEN

This decision may be subject to appeal before the Council of State within two months from its notification.